

Reporte de Gestión de Incidentes ISO 27001

Vulnerabilidad de SQL Injection en DVWA

Introducción

Este informe pretende documentar la detección, análisis y explotación de una vulnerabilidad **SQL Injection** dentro de un entorno controlado como puede ser Damn Vulnerable Web Application (DVWA). Dicha actividad busca comprender y demostrar cómo una mala validación de entradas puede comprometer un sistema web. El proceso incluyó la instalación del entorno hasta la ejecución del ataque, así mismo como la resolución de problemas técnicos relacionados con la configuración de base de datos.

Descripción del Incidente

En las pruebas de seguridad realizadas en la aplicación DVWA, se identificó una vulnerabilidad de suma importancia en el módulo de SQL Injection. Esta debilidad permite a un atacante inyectar comandos SQL a través del campo de entrada destinado al ID de usuario, lo que podría comprometer tanto la confidencialidad como la integridad de los datos almacenados en la base de datos.

Antes de poder realizar la explotación de la vulnerabilidad, se detectó un problema en los permisos del usuario *root* en MySQL. Este error impedía la conexión entre DVWA y la base de datos, y arrojaba el mensaje:

Access denied for user 'root'@'localhost'

La solución a dicho problema fue ajustar el archivo *config.inc.php* con las credenciales correctas y otorgarle los permisos adecuados en MySQL.

Proceso de Reproducción

- **Paso 1:** Proceder con la instalación de DVWA en un entorno Linux, en este caso de una máquina virtual Kali.
- **Paso 2:** Comprobar que Apache y MySQL están activos además de configurarlos.
- **Paso 3:** Resolución de posibles errores en este caso, los permisos para el usuario *root*.
- **Paso 4:** Asignación de permisos de usuario con:

sudo chown -R www-data:www-data /var/www/html/DVWA/

```
sudo chmod -R 755 /var/www/html/DVWA/
```

A su vez asignar permisos a root con:

```
GRANT ALL PRIVILEGES ON DVWA.* TO 'root'@'localhost' IDENTIFIED  
BY 'kali';  
FLUSH PRIVILEGES;
```

- **Paso 5:** Acceder en <http://localhost/DVWA/setup.php>, en donde hay despliegue de una página y creación de la base de datos desde la interfaz.
- **Paso 6:** Se accede al módulo "SQL Injection" que se encuentra en la plataforma.
- **Paso 7:** Inyección de la siguiente cadena en el campo de ID de usuario:

```
1' OR '1'='1
```

- **Paso 8:** Obtención de múltiples resultados de usuarios almacenados en la base de datos, demostrando que la aplicación es vulnerable a SQL Injection.

Impacto del Incidente

La explotación de esta vulnerabilidad permitió:

- Acceder a información sensible de todos los usuarios almacenados en la base de datos.
- Realizar consultas no autorizadas que podrían ser extendidas para modificar o eliminar datos críticos.
- Exponer nombres de usuario y estructuras internas de la base de datos.

Si este fuese un escenario real esta explotación de la vulnerabilidad puede constituir una violación legal al RGPD si hay datos personales comprometidos. Incumpliendo los Artículos del RGPD / LOPDGDD número 5, 25, 32, 33.

Irrumpiendo en el tratamiento, seguridad y protección de los datos y el manejo de la seguridad de la información.

Recomendaciones

1. **Validación de entradas:** Utiliza prepared statements o consultas parametrizadas para prevenir inyecciones.

2. **Manejo de errores:** Configurar la aplicación para que no muestre errores detallados de base de datos al usuario.
 3. **Pruebas de seguridad periódicas:** Ejecutar análisis de vulnerabilidades y pentesting regularmente.
 4. **Principio de mínimo privilegio:** Evitar usar el usuario root en aplicaciones web. En su lugar se podría crear un usuario limitado sólo para lectura y/o escritura en la base específica.
 5. **Capacitación:** Formar a los desarrolladores en prácticas seguras de codificación y gestión de incidentes.
-

Conclusiones

El ejercicio DVWA demostró cómo puede ser posible la explotación de una vulnerabilidad de inyección SQL para obtener acceso no autorizado a información sensible. También dejó claro cómo la falta de atención a los detalles, como conceder demasiado acceso a determinados usuarios con respecto a la base de datos, puede representar un grave riesgo para la seguridad.

Este incidente demuestra cómo deben imponerse medidas de protección adecuadas desde las primeras fases del desarrollo de software, junto con la necesidad de revisiones continuas para garantizar la integridad del sistema.

En un entorno real, esta explotación se podría considerar una violación de las leyes de protección de datos como la Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD) como el Reglamento General de Protección de Datos (GDPR). Ya que vulnera principios fundamentales de confidencialidad y de integridad de los datos, además de incumplir obligaciones legales asociadas a la seguridad de los datos tratados.

Es por ello que es de suma importancia comprender que los fallos técnicos no solo suponen un riesgo operativo, sino también un riesgo legal y de reputación para cualquier entidad.